

# DOC-007: FIREWALL RULE REQUEST

UFOSI — Universal Financing Optimized Syariah Intelligent-assistant

## A. METADATA & GOVERNANCE CONTROL

| Parameter Tata Kelola | Deskripsi & Identifikasi Dokumen                                                                                  |
|-----------------------|-------------------------------------------------------------------------------------------------------------------|
| Kode Dokumentasi      | DOC-007                                                                                                           |
| Fase Tata Kelola      | Technology Architecture Phase — SDLC Mapping: Network Security Implementation                                     |
| Versi Master          | v1.1.0 — Updated: 04 June 2026                                                                                    |
| Status Dokumen        | <input checked="" type="checkbox"/> Draft <input type="checkbox"/> Under Review <input type="checkbox"/> Approved |

## B. ACCOUNTABILITY & READINESS MATRIX

| Peran Tata Kelola           | Aktor / Pemangku Kepentingan                           | Uraian Tanggung Jawab Operasional & Kesiapan                                                                                                                                                                                                                                                                                                             |
|-----------------------------|--------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Document Owner              | IT Network & Security Operation Team / Security Stream | Bertanggung jawab mengevaluasi tingkat risiko pembukaan port, memverifikasi keselarasan dengan DOC-006 Network Connectivity Requirement, melakukan eksekusi atau konfigurasi pada perangkat firewall bank/simulasi firewall internal, serta berhak melakukan penolakan jika terdapat indikasi port tidak aman atau tidak sesuai prinsip least privilege. |
| Target User Input           | Lead Developer / Dev Stream                            | Wajib mengisi seluruh parameter teknis pengajuan pembukaan aturan keamanan atau firewall rules secara detail untuk mendukung kelancaran interkoneksi container UFOSI.                                                                                                                                                                                    |
| IT Operations Team          | IT Operations / Platform Team                          | Bertanggung jawab melakukan validasi akses SSH, NodePort, monitoring endpoint, dan komunikasi internal service, serta menyediakan evidence hasil testing rule.                                                                                                                                                                                           |
| IT Security Reviewer        | Security Operation / Risk Compliance                   | Bertanggung jawab melakukan review terhadap port berisiko tinggi, exposure service, outbound API eksternal, serta memastikan tidak ada akses publik yang tidak disetujui.                                                                                                                                                                                |
| Project Manager / Task Lead | UFOSI Task Lead                                        | Bertanggung jawab memastikan masa aktif rule sesuai periode demo/UAT dan melakukan koordinasi apabila terdapat perubahan kebutuhan konektivitas.                                                                                                                                                                                                         |

## C. STRATEGIC PURPOSE / TUJUAN OPERASIONAL

Dokumen ini merupakan formulir pengajuan formal yang bersifat mandatori untuk meminta izin pembukaan jalur komunikasi data atau Firewall Access Rule pada perimeter jaringan internal/simulasi internal proyek UFOSI di lingkungan Bank Syariah Indonesia.

Berdasarkan arsitektur UFOSI atau Universal Financing Optimized Syariah Intelligent-assistant yang mengisolasi komponen mikro berbasis container, dokumen ini memastikan bahwa prinsip keamanan terkecil atau Principle of Least Privilege diterapkan secara ketat. Port jaringan hanya dibuka secara spesifik sesuai kebutuhan, dengan source, destination, protocol, port, action, durasi, dan justifikasi yang terdokumentasi.

Dokumen ini juga menjadi dasar bagi tim Network & Security Operation untuk meninjau risiko pembukaan port, mencegah akses ilegal antar-subnet, menghindari exposure service sensitif seperti database dan AI/OCR engine, serta memastikan rule yang diberikan hanya bersifat sementara untuk kebutuhan Demo/UAT.

## D. CONTENTS & ACTIONABLE REGISTER

### Dev & Security Input

Bagian ini wajib diisi dengan lengkap dan presisi untuk menghindari penolakan dari tim Security Network Operation BSI.

# 1. Informasi Umum Pengajuan

## Request Overview

| Atribut Pengajuan                 | Detail Isian Parameter Akses                                                                                                                                                                                 |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Nama Sistem / Proyek Terkait      | UFOSI — Universal Financing Optimized Syariah Intelligent-assistant                                                                                                                                          |
| Environment                       | Demo / UAT                                                                                                                                                                                                   |
| Deployment Host Utama             | VM 1 / ubuntu-itops1 / 192.168.23.72                                                                                                                                                                         |
| Automation / Network Support Host | VM 2 / ubuntu-itops2 / 192.168.23.71                                                                                                                                                                         |
| Application Namespace             | ufosi                                                                                                                                                                                                        |
| Monitoring Namespace              | monitoring                                                                                                                                                                                                   |
| Tipe Aksi Pengajuan Rule          | <input checked="" type="checkbox"/> Pembukaan Jalur Baru / New Rule Requested<br><input type="checkbox"/> Modifikasi Jalur Lama<br><input type="checkbox"/> Penutupan Jalur / Rule Decommissioning           |
| Sifat Durasi Akses Jalur          | <input type="checkbox"/> Permanen — untuk produksi utama<br><input checked="" type="checkbox"/> Temporer / sementara — kebutuhan evaluasi dan demo tugas                                                     |
| Masa Berlaku Aktif                | Mulai: 04 June 2026<br>Selesai: 09 June 2026                                                                                                                                                                 |
| Klasifikasi Akses                 | <input checked="" type="checkbox"/> Internal Lab Network / Intranet Simulation<br><input type="checkbox"/> Public Internet Facing<br><input type="checkbox"/> External Partner Access                        |
| Prinsip Pembukaan Port            | Hanya port yang diperlukan untuk administrasi, akses frontend demo, monitoring, dan komunikasi internal service yang diajukan. Backend, AI/OCR, dan PostgreSQL tidak boleh diexpose langsung ke client/user. |
| Referensi Dokumen                 | DOC-006 Network Connectivity Requirement, DOC-020 Hardening Checklist, DOC-022 Operational Readiness Assessment, DOC-025 Service Operation Runbook, dan DOC-028 Monitoring & Alert Matrix.                   |

# 2. Daftar Tabel Aturan Firewall yang Diajukan

## Firewall Rules Registry

Mohon isi tabel di bawah ini dengan merujuk langsung pada pemetaan topologi interkoneksi di DOC-006 Network Connectivity Requirement.

| No | Source IP / Subnet Asal                                                               | Destination IP / Subnet Tujuan                                                | Protocol | Destination Port      | Action             | Status                  |
|----|---------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|----------|-----------------------|--------------------|-------------------------|
| 1  | PC 2 / Admin Workstation<br>192.168.23.186/32 atau IP client internal terbaru         | VM 1 / ubuntu-itops1<br>192.168.23.72/32                                      | TCP      | 22                    | ALLOW<br>TEMPORARY | Pending Security Review |
| 2  | PC 2 / Admin Workstation<br>192.168.23.186/32 atau IP client internal terbaru         | VM 2 / ubuntu-itops2<br>192.168.23.71/32                                      | TCP      | 22                    | ALLOW<br>TEMPORARY | Pending Security Review |
| 3  | VM 2 / ubuntu-itops2<br>192.168.23.71/32                                              | VM 1 / ubuntu-itops1<br>192.168.23.72/32                                      | ICMP     | ICMP                  | ALLOW<br>TEMPORARY | Pending Security Review |
| 4  | VM 2 / ubuntu-itops2<br>192.168.23.71/32                                              | VM 1 / ubuntu-itops1<br>192.168.23.72/32                                      | TCP      | 22                    | ALLOW<br>TEMPORARY | Pending Security Review |
| 5  | PC 2 Browser / User Demo<br>192.168.23.186/32 atau IP client internal terbaru         | VM 1 Frontend UFOSI NodePort<br>192.168.23.72/32                              | TCP      | 30080                 | ALLOW<br>TEMPORARY | Pending Security Review |
| 6  | VM 2 / Network Testing Node<br>192.168.23.71/32                                       | VM 1 Frontend UFOSI NodePort<br>192.168.23.72/32                              | TCP      | 30080                 | ALLOW<br>TEMPORARY | Pending Security Review |
| 7  | UFOSI Frontend Service /<br>Kubernetes Service Network namespace ufosi                | UFOSI Backend API Service /<br>Kubernetes Service Network namespace ufosi     | TCP      | 8080                  | ALLOW<br>INTERNAL  | Pending Security Review |
| 8  | UFOSI Backend API Service /<br>Kubernetes Service Network namespace ufosi             | UFOSI AI/OCR Engine Service /<br>Kubernetes Service Network namespace ufosi   | TCP      | 8000                  | ALLOW<br>INTERNAL  | Pending Security Review |
| 9  | UFOSI Backend API Service /<br>Kubernetes Service Network namespace ufosi             | PostgreSQL Database Service /<br>Kubernetes Service Network namespace ufosi   | TCP      | 5432                  | ALLOW<br>INTERNAL  | Pending Security Review |
| 10 | PC 2 / Ops User / Browser Client<br>192.168.23.186/32 atau IP client internal terbaru | Grafana Dashboard Service on<br>VM 1 / Monitoring Service<br>192.168.23.72/32 | TCP      | 30300                 | ALLOW<br>TEMPORARY | Pending Security Review |
| 11 | PC 2 / Ops User / Browser Client<br>192.168.23.186/32 atau IP client internal terbaru | Prometheus Service on VM 1 /<br>Monitoring Service<br>192.168.23.72/32        | TCP      | 30090                 | ALLOW<br>TEMPORARY | Pending Security Review |
| 12 | Prometheus / Monitoring<br>Namespace                                                  | Node Exporter / Kubernetes<br>Metrics Target / Internal Metrics Endpoint      | TCP      | 9090 / 9100 /<br>8080 | ALLOW<br>INTERNAL  | Pending Security Review |
| 13 | Client Zone / PC 2<br>192.168.23.186/32 atau IP client internal terbaru               | UFOSI Backend API Service                                                     | TCP      | 8080                  | DENY               | Pending Security Review |
| 14 | Client Zone / PC 2<br>192.168.23.186/32 atau IP client                                | UFOSI AI/OCR Engine Service                                                   | TCP      | 8000                  | DENY               | Pending Security Review |

| No | Source IP / Subnet Asal                                                                        | Destination IP / Subnet Tujuan           | Protocol | Destination Port | Action               | Status                  |
|----|------------------------------------------------------------------------------------------------|------------------------------------------|----------|------------------|----------------------|-------------------------|
| 15 | internal terbaru<br>Client Zone / PC 2<br>192.168.23.186/32 atau IP client<br>internal terbaru | PostgreSQL Database Service              | TCP      | 5432             | DENY                 | Pending Security Review |
| 16 | External Client / Non-Admin<br>Source                                                          | VM 1 / ubuntu-itops1<br>192.168.23.72/32 | TCP      | 22               | DENY                 | Pending Security Review |
| 17 | External Client / Non-Admin<br>Source                                                          | VM 2 / ubuntu-itops2<br>192.168.23.71/32 | TCP      | 22               | DENY                 | Pending Security Review |
| 18 | AI/OCR Pod UFOSI / namespace<br>ufosi                                                          | External Gemini API Endpoint             | TCP      | 443              | ALLOW<br>CONDITIONAL | Pending Security Review |

3. Justifikasi Firewall Rule

| Rule No | Justifikasi Operasional                                                                                                                                       | Risk Note / Mitigasi                                                                                                                           |
|---------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| 1–2     | Dibutuhkan untuk akses administrasi VM 1 dan VM 2 oleh admin workstation internal selama konfigurasi, deployment, validasi service, dan pengumpulan evidence. | SSH port 22 termasuk port manajemen berisiko tinggi, sehingga hanya boleh dibuka dari IP admin internal yang disetujui dan bersifat sementara. |
| 3–4     | Dibutuhkan untuk validasi konektivitas dasar dan akses antar-VM dari VM 2 ke VM 1.                                                                            | Akses dibatasi hanya antara VM internal lab. Tidak boleh diperluas ke subnet publik.                                                           |
| 5–6     | Dibutuhkan untuk akses frontend UFOSI dari browser demo dan testing node.                                                                                     | Hanya frontend NodePort 30080 yang boleh menjadi entry point user.                                                                             |
| 7       | Dibutuhkan agar frontend dapat berkomunikasi dengan backend API dalam namespace aplikasi.                                                                     | Komunikasi internal service. Tidak dibuka langsung ke client.                                                                                  |
| 8       | Dibutuhkan agar backend dapat mengirim dokumen ke AI/OCR engine untuk parsing dan analisis.                                                                   | AI/OCR tidak boleh diakses langsung oleh user.                                                                                                 |
| 9       | Dibutuhkan agar backend dapat membaca dan menulis data ke PostgreSQL.                                                                                         | Database hanya boleh diakses oleh backend/service terkait.                                                                                     |
| 10–11   | Dibutuhkan untuk akses monitoring Prometheus dan Grafana oleh tim IT Ops selama demo/UAT.                                                                     | Akses monitoring dibatasi ke Ops user internal dan tidak boleh dibuka publik.                                                                  |
| 12      | Dibutuhkan untuk scraping metrics oleh Prometheus dari node/service target.                                                                                   | Hanya internal monitoring traffic.                                                                                                             |
| 13–15   | Rule DENY eksplisit untuk mencegah akses langsung client ke backend, AI/OCR, dan database.                                                                    | Memastikan frontend menjadi satu-satunya jalur akses user.                                                                                     |
| 16–17   | Rule DENY eksplisit untuk mencegah akses SSH dari external/non-admin source.                                                                                  | Mendukung prinsip least privilege dan mengurangi risiko brute force.                                                                           |
| 18      | Koneksi outbound HTTPS ke Gemini API hanya jika fitur AI/OCR membutuhkan external AI service.                                                                 | Harus direview IT Security, tidak boleh membawa data nasabah riil, dan wajib menggunakan data dummy/anonymized pada demo.                      |

4. Validasi Keamanan Tambahan & Kepatuhan Risiko

Security Risk & Compliance Notes

Bagian ini akan ditinjau langsung oleh tim Security Operation Stream.

| Parameter Validasi Risiko Security             | Catatan Kebijakan & Mitigasi                                                                                                                                                                                                                                                                                                                                                                                                   |
|------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Pembukaan Port Risiko Tinggi seperti SSH / RDP | <div><input type="checkbox"/> Tidak ada pembukaan port manajemen OS</div> <div><input checked="" type="checkbox"/> Ada pembukaan SSH port 22 secara terbatas hanya untuk workstation admin terotorisasi</div> <div><input type="checkbox"/> Ya, pembukaan luas ke banyak subnet / publik</div> <div>Mitigasi: SSH hanya dibuka untuk IP admin internal, menggunakan user yang sah, dan bersifat temporer untuk Demo/UAT.</div> |
| Pembukaan Backend API                          | <div><input checked="" type="checkbox"/> Backend API tidak dibuka langsung ke client/user</div> <div><input type="checkbox"/> Backend API dibuka ke subnet user</div> <div><input type="checkbox"/> Backend API dibuka publik</div> <div>Mitigasi: Backend hanya boleh diakses oleh frontend service atau jalur internal yang disetujui.</div>                                                                                 |
| Pembukaan AI/OCR Service                       | <div><input checked="" type="checkbox"/> AI/OCR tidak dibuka langsung ke client/user</div> <div><input type="checkbox"/> AI/OCR dibuka ke subnet user</div> <div><input type="checkbox"/> AI/OCR dibuka publik</div> <div>Mitigasi: AI/OCR hanya menerima request dari backend service.</div>                                                                                                                                  |
| Pembukaan Database PostgreSQL                  | <div><input checked="" type="checkbox"/> PostgreSQL tidak dibuka langsung ke client/user</div> <div><input type="checkbox"/> PostgreSQL dibuka ke subnet user</div> <div><input type="checkbox"/> PostgreSQL dibuka publik</div> <div>Mitigasi: Port 5432 hanya boleh digunakan oleh backend/service internal.</div>                                                                                                           |
| Pembukaan Monitoring                           | <div><input checked="" type="checkbox"/> Grafana dan Prometheus dibuka sementara untuk Demo/UAT</div> <div><input type="checkbox"/> Monitoring dibuka permanen</div> <div><input type="checkbox"/> Monitoring dibuka publik</div> <div>Mitigasi: Akses monitoring dibatasi untuk tim IT Ops dan reviewer teknis internal. Grafana wajib menggunakan login.</div>                                                               |

| Parameter Validasi Risiko Security | Catatan Kebijakan & Mitigasi                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Outbound External API              | <div><div><div><input type="checkbox"/> Tidak ada outbound external API</div><div><input checked="" type="checkbox"/> Ada bersyarat apabila fitur Gemini API digunakan</div><div><input type="checkbox"/> Ada outbound permanen ke internet publik</div></div><div>Mitigasi: Outbound ke Gemini API hanya berlaku jika fitur AI/OCR final membutuhkan external inference. Wajib review IT Security dan tidak boleh mengirim data nasabah riil saat demo.</div></div> |
| Kebutuhan Load Balancer / DNS      | <div><div><div><input checked="" type="checkbox"/> Tidak dibutuhkan untuk Demo/UAT</div><div><input type="checkbox"/> Dibutuhkan URL internal khusus</div><div><input type="checkbox"/> Dibutuhkan public DNS</div></div></div>                                                                                                                                                                                                                                      |
| Ketergantungan Dokumen Pendukung   | <div><div>Pengajuan ini didasarkan pada cetak biru interkoneksi formal yang tertera pada DOC-006 Network Connectivity Requirement dan wajib disinkronkan dengan DOC-020 Hardening Checklist, DOC-022 Operational Readiness Assessment, DOC-025 Service Operation Runbook, dan DOC-028 Monitoring &amp; Alert Matrix.</div></div>                                                                                                                                     |
| Klasifikasi Durasi Rule            | <div><div><div><input checked="" type="checkbox"/> Temporer / sementara untuk kebutuhan Demo/UAT</div><div><input type="checkbox"/> Permanen untuk Production</div></div></div>                                                                                                                                                                                                                                                                                      |
| Internet Facing Exposure           | <div><div><div><input checked="" type="checkbox"/> Tidak ada inbound internet-facing exposure</div><div><input type="checkbox"/> Ada inbound internet-facing exposure</div></div><div>Mitigasi: Seluruh akses dilakukan melalui internal lab network / intranet simulation.</div></div>                                                                                                                                                                              |
| Data Protection Note               | <div><div>Seluruh pengujian/demo wajib menggunakan dummy data atau anonymized data. Tidak boleh mengirim dokumen rekening koran nasabah riil ke external API.</div></div>                                                                                                                                                                                                                                                                                            |

5. Post-Implementation Validation Checklist

| No | Area Validasi                          | Command / Metode Validasi                                | Expected Result                                                 |
|----|----------------------------------------|----------------------------------------------------------|-----------------------------------------------------------------|
| 1  | SSH PC 2 ke VM 1                       | ssh <user>@192.168.23.72                                 | Login SSH berhasil dari admin workstation internal.             |
| 2  | SSH PC 2 ke VM 2                       | ssh <user>@192.168.23.71                                 | Login SSH berhasil dari admin workstation internal.             |
| 3  | Ping VM 2 ke VM 1                      | ping 192.168.23.72                                       | ICMP reply berhasil.                                            |
| 4  | Test port SSH VM 1 dari VM 2           | nc -vz 192.168.23.72 22                                  | Port 22 reachable hanya dari source yang diizinkan.             |
| 5  | Akses Frontend                         | Browser / curl http://192.168.23.72:30080                | Halaman frontend UFOSI dapat diakses dari client demo internal. |
| 6  | Akses Grafana                          | Browser http://192.168.23.72:30300                       | Grafana login page tampil untuk Ops user.                       |
| 7  | Akses Prometheus                       | Browser http://192.168.23.72:30090                       | Prometheus UI tampil untuk Ops user.                            |
| 8  | Backend direct access dari client      | curl http://192.168.23.72:8080 atau sesuai service       | Tidak boleh terbuka langsung ke client/user.                    |
| 9  | PostgreSQL direct access dari client   | nc -vz 192.168.23.72 5432                                | Tidak boleh terbuka langsung ke client/user.                    |
| 10 | AI/OCR direct access dari client       | nc -vz 192.168.23.72 8000                                | Tidak boleh terbuka langsung ke client/user.                    |
| 11 | Cek service Kubernetes                 | kubectl get svc -n ufosi                                 | Service sesuai exposure yang disetujui.                         |
| 12 | Cek monitoring service                 | kubectl get svc -n monitoring                            | Prometheus dan Grafana service aktif.                           |
| 13 | Cek port listening host                | ss -tulpen                                               | Tidak ada port tambahan yang tidak terdokumentasi.              |
| 14 | Cek firewall lokal                     | sudo ufw status                                          | Rule sesuai daftar allow/deny yang disetujui.                   |
| 15 | Cek outbound Gemini API jika digunakan | curl -I https://<endpoint-gemini> atau validasi aplikasi | Hanya berhasil jika rule conditional disetujui security.        |

6. Rule Decommission Plan

| Area                     | Rencana Penutupan / Revalidasi                                                                                                                                                        |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Masa Berlaku Rule        | Rule berlaku sementara mulai 04 June 2026 sampai 10 June 2026.                                                                                                                        |
| Setelah Demo/UAT Selesai | Tim IT Ops dan Security melakukan review apakah rule perlu ditutup, diperpanjang, atau dimodifikasi.                                                                                  |
| Rule SSH                 | SSH hanya dipertahankan untuk admin source yang sah. Source lain tetap deny.                                                                                                          |
| Rule Frontend NodePort   | NodePort 30080 dapat ditutup jika environment demo tidak digunakan lagi.                                                                                                              |
| Rule Monitoring          | Prometheus dan Grafana NodePort ditutup atau dibatasi ulang setelah kebutuhan evaluasi selesai.                                                                                       |
| Rule Outbound Gemini API | Jika tidak digunakan, rule outbound 443 ke Gemini API wajib dinonaktifkan. Jika digunakan untuk pengembangan lanjutan, wajib dibuat pengajuan permanen/khusus dengan review security. |
| Rule Internal Service    | Komunikasi internal tetap dikelola melalui Kubernetes service/network policy sesuai kebutuhan environment.                                                                            |
| Evidence Closure         | Simpan evidence hasil penutupan/revalidasi rule sebagai bagian dari dokumentasi operasional.                                                                                          |

7. Kesimpulan Firewall Request

Berdasarkan kebutuhan network connectivity UFOSI, firewall rule yang diajukan bersifat terbatas, internal-only, dan temporer untuk kebutuhan Demo/UAT. Port yang dibuka hanya mencakup akses administrasi SSH dari workstation

admin internal, akses frontend UFOSI melalui NodePort 30080, akses monitoring Prometheus/Grafana untuk tim IT Ops, serta komunikasi internal antar-service Kubernetes.

Backend API, AI/OCR service, dan PostgreSQL tidak boleh diexpose langsung ke client/user. Akses langsung dari client ke port 8080, 8000, dan 5432 harus ditolak melalui rule DENY atau tidak dibuka sama sekali pada perimeter jaringan.

Outbound ke Gemini API melalui port 443 hanya bersifat conditional apabila fitur AI/OCR benar-benar membutuhkan external API. Rule ini wajib direview oleh IT Security dan tidak boleh digunakan untuk mengirim data rekening koran asli atau data nasabah riil pada fase demo.

Dokumen DOC-007 ini menjadi dasar formal pengajuan, review, implementasi, validasi, dan decommission firewall rule untuk proyek UFOSI.